2026（第八届）FinTechathon 深圳国际金融科技大赛

微众银行金融科技大学生挑战赛

国内人工智能赛道　银行 AI 智能体

TROPOS

自适应银行智能体

技术设计与实现说明

系统版本 3.2.9　文档修订版 2.0

千人千策，随境而变

TROPOS 项目组　2026 年 11 月 2 日

赛题主题：AI 代人操作银行　安全与体验

摘要

TROPOS 面向自然语言办理银行事务这一场景，研究如何让智能体理解一个人的财务处境，并在可核验的约束下形成安排。项目将长期偏好与短期现金状态分别记录，以知己 ETHOS、善谋 METIS、择时 KAIROS、守诺 ARGOS 四种职责贯通画像、策略、计划、执行与反馈。相同请求可以因现金缓冲、到期义务和目标期限而产生不同安排；收入或账单变化后，未执行计划需要重新核验。

当前 3.2.9 提供合成银行沙箱中的转账、账单与财务体检、订阅办理、卡片及理财演示、多步骤任务与生活规划。大模型参与语义理解、候选规划、只读问答和来源化检索；金额、账户事实、操作条件、授权和记账由服务端控制。转账草案与确认执行分离，利用事务、版本号、确认令牌和幂等记录处理过期、并发与重试。未来 30 天现金路径使用整数分计算，生活规划在用户允许的离散选项内比较安排，不把预计收入视为当前可支付余额。

本文给出职责到代码的映射、核心算法、状态转换、接口与数据边界、部署方法和验证口径。银行账本及银行回执为合成数据；美团官方连接器可能涉及真实授权、地址和订单，实际支付由用户在美团完成，不写入合成银行账本。当前版本未接入真实银行，也没有后台自动资金执行器。

关键词：银行智能体；动态金融画像；现金流约束；分级授权；可解释规划；幂等记账。

版本与阅读说明

核心代码基线为 2a330635e1a9f05e29125324d1a7d74552b8a2e8；界面采用 2026 年 11 月 2 日本地工作区的水墨风更新。文档所述实现以核心代码及本次核查为准，页面视觉更新不等于后端能力升级。代码快照、测试命令与证据文件见第 9 节及附录。原稿中的历史测试成绩与本次复跑结果分别列示，不直接相加。

目录

摘要 **i**

1 项目出发点与设计目标 **1**

1.1 从一笔指令到一份适合当下的安排 1

1.2 四种资金需要与项目版图 1

1.3 赛题对应与实现边界 2

2 总体架构与四引擎协作 **2**

2.1 分层结构与信任边界 2

2.2 职责到工程模块的映射 3

2.3 画像到反馈的闭环 3

3 确定性现金计算与可解释规划 **4**

3.1 现金路径的精确定义 4

3.2 一组可以独立复算的合成算例 4

3.3 财务体检的证据与规则 5

3.4 生活规划的有限离散搜索 5

4 对话办理与状态变更控制 **6**

4.1 从自然语言到待确认对象 6

4.2 普通转账的草案与确认契约 6

4.3 多步骤任务与部分完成 7

5 模型中心与受限智能编排 **8**

5.1 模型配置与本地回退 8

5.2 发往模型的数据契约 8

5.3 结构化方案与服务端上限 8

5.4 3.2.9 的千问稳定性修复 9

6 购物链路与外部服务隔离 **9**

6.1 模拟购物与真实跑腿分开记账 9

6.2 用户授权与提交控制 10

6.3 组件调用与凭据空间 10

6.4 邮件服务的真实副作用 11

7　数据模型与身份安全　11

7.1　持久化对象与版本 11

7.2　注册账户与共享演示账户 11

7.3　接入校验与权限边界 12

7.4　可信本机配置与残余风险 12

8　部署拓扑与运行维护　13

8.1　运行环境与服务入口 13

8.2　Linux Docker 与 HTTPS 13

8.3　升级与故障恢复 14

9　验证方法与本次核验结果　14

9.1　可复现基线与计数口径 14

9.2　红队样例与结论边界 15

9.3　与技术主张对应的证据 15

10　版本演进与后续工作　16

10.1　3.2 系列的工程收敛 16

10.2　优先完成的工程改进 16

10.3　面向更完整金融生活的方向 16

A　接口与工程核对索引　17

A.1　主要接口契约 17

A.2　工程模块与核查函数 18

A.3　交付与复现 18

1. 项目出发点与设计目标

1.1 从一笔指令到一份适合当下的安排

银行提供的操作能力日益丰富，但用户仍要在收入、账单、家庭责任与生活目标之间，自己拼出一份安排。“帮我打理这两万元”对现金紧张者和储备充足者，不应产生相同的行动；昨天能够执行的计划，也可能因工资延期而在今天失去可行性。TROPOS 的出发点，是让银行智能体先理解资金在生活中的位置，再决定可以准备什么操作。

“千人千策，随境而变”在工程上对应两个要求。一是个体差异进入决策条件：现金底线、必要支付、期限与用户主动声明的偏好，影响建议空间和核验结果。二是状态变化进入后续决策：收入到账、延期、账单变化或画像更正，会改变账户状态或版本，使旧方案接受重新检查。系统不把一次问卷变成永久标签，也不因为一次收入冲击擅自改变用户的长期目标。

项目面向比赛评审和可复现的技术验证，核心问题是如何把模型生成与金融状态变更衔接起来：允许模型理解自然语言与提出候选安排，同时以确定性业务服务掌握事实与执行权。本文将产品立意落实到数据结构、约束、确认过程和回执，而不是以功能数量代替这一主线。

1.2 四种资金需要与项目版图

Protect、Recover、Accumulate、Grow 分别对应现金流守护、负债减压、财富积累与长期资金安排。它们是随处境变化的任务重点，可以并存，也可以调整；不能依据年龄、职业等身份直接为用户分配固定金融策略。

表 1　资金需要与当前实现的对应关系

任务重点	要回答的问题	当前可体验的支撑
现金流守护	必要账单和生活缓冲能否保留	30 天现金路径、现金底线、事件冲击复核
负债减压	到期义务怎样排序与核对	还款与账单汇总、订阅复核、多步骤任务
财富积累	日常之外能为目标留出多少空间	目标储蓄草案、生活安排比较、预算核验
长期资金安排	用钱期限与风险约束是否匹配	主动风险声明、期限与流动性核对、理财沙箱

产品由三层场景连接起来：银行事务提供转账、查询、订阅及卡片等操作工具；现金规划判断近期约束与目标空间；生活联动把家庭、购物、教育、健康和出行等需要放在同一份资金日历中。长期愿景是持续适应人的财务变化；当前落点仍是有限期限、明确授权、可核验的比赛原型。

1.3　赛题对应与实现边界

赛事国内人工智能方向聚焦银行 AI 智能体，通过自然语言理解意图、规划并办理业务，兼顾安全与体验。TROPOS 以转账、账单分析与订阅办理为基础，扩展卡片、理财沙箱及生活联动。赛题名称依据赛事官网，访问日期为 2026 年 11 月 2 日[1]。

银行沙箱中的账户、余额、交易、复式分录和银行回执均为合成记录，不连接真实银行清算。美团官方链路、外部模型和 SMTP 则可能产生真实的对外请求；它们分别受连接器、数据边界与部署配置约束。真实美团订单创建不等于合成银行付款，跳转收银台也不等于支付成功。

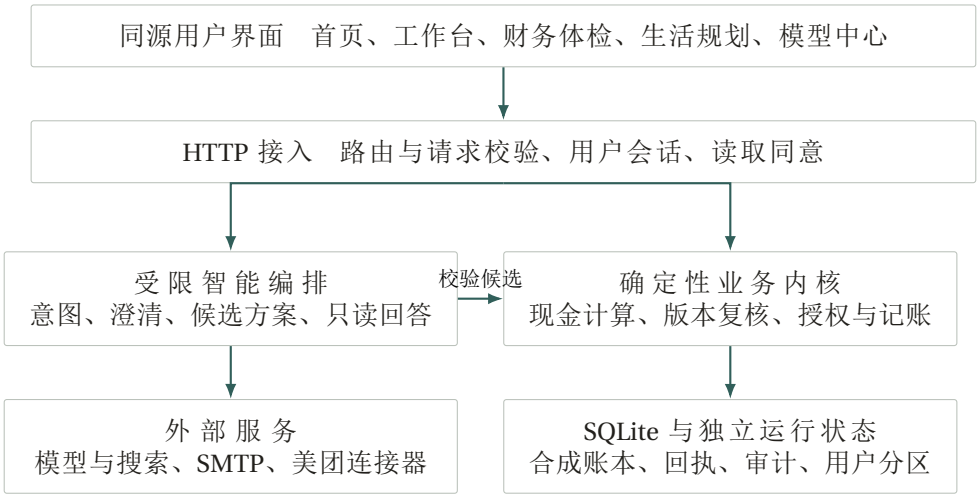
系统当前没有实名核验、银行卡要素认证、生产清算、持续后台自动付款或经过验证的完整生命周期模型。页面中的资金预测是基于已知输入的条件计算，不是工资到账保证、收益承诺或完整财务风险评估。

2.　总体架构与四引擎协作

2.1　分层结构与信任边界

系统采用同源网页、Python 标准库 HTTP 服务与 SQLite 数据库。页面负责输入、展示、选择和独立确认；网关解析会话及请求；业务服务读取事实、计算约束并执行状态变更。模型返回值与外部网页内容均作为待检查的数据，不因来源于模型而获得授权。

图 1　系统分层与对外连接边界



外部连接不共享银行账本执行权。美团真实支付在用户与美团之间完成，订单状态与合成银行交易分别记录。

后端以模块而非独立模型进程组织职责：server.py 提供接入，service.py 管理账户、身份和账本，conversation.py 与 agent_ops.py 编排任务，model.py 适配模型，life_planner.py

[1]FinTechathon 赛事官网：https://fintechathon.g-ican.com/。本文不据官网介绍推定未公开的评分权重或宣称已经通过赛事验收。

执行有限期规划。四引擎是贯穿这些模块的逻辑职责，不要求四个大模型分别驻留，也不暗示存在未实现的自主协商网络。

2.2　职责到工程模块的映射

表 2　四引擎职责及其可观察产物

职责	输入与判断	实现位置与产物
ETHOS 知己	目标、期限、风险声明、现金状态、用户更正	画像规则与 service.py；版本化画像、当前任务侧重及原因
METIS 善谋	账单、现金约束、允许的行动与候选方案	model.py、life_planner.py、agent_ops.py；可核验方案与有序任务
KAIROS 择时	显式收入事件、当前日期条件、计划有效期与账户版本	service.py、life_service.py、conversation.py；等待、失效、复核与重新生成
ARGOS 守诺	身份、授权、对象、金额、计划版本、确认与回执	server.py、service.py、agent_ops.py；拒绝、澄清、二次核验及原子记账

ARGOS 的作用贯穿生成与执行：草案阶段检查可行性，确认阶段复核当前事实，执行阶段检查幂等与账本一致性。它拥有停止推进的业务效果，而不是在流程末尾补一句安全提示。KAIROS 的现有触发来自明确请求、演示事件与确认时检查；没有后台常驻事件执行器，条件满足后仍须重新核验与确认。

2.3　画像到反馈的闭环

用户首先声明目标、现金底线、用钱期限、流动性与风险意愿，并明确是否同意读取所需信息。画像层保留这些长期声明，账本层单独记录余额、账单、工资状态和版本。策略层据此约束候选空间，计划层形成可以逐项查看的步骤，业务层只执行当前有效且已经确认的动作。回执、用户更正和新事件成为后续判断的输入。

例如工资延期只改变短期收入时点，不等于用户同意提高风险或降低现金底线。现金路径重算后，原先可行的转账草案可能因账户版本变化而失效。系统应解释为何需要重看、保留已完成操作的回执，并为未执行部分重新准备草案；不把原来的授权延伸为新安排的空白授权。

3. 确定性现金计算与可解释规划

3.1 现金路径的精确定义

金融计算使用整数分。金额入口拒绝布尔值、非有限数和超过分精度的输入，避免把浮点累计误差带入余额判断。设主账户已到账余额为 B，假设立即转出额为 D，每日演示开销为 d，第 t 天的有符号事件金额之和为 F_t。则：

$$C_0 = B - D, \tag{1}$$

$$C_t = C_{t-1} - d + F_t, \qquad t = 1, \dots, 30, \tag{2}$$

$$C_{\min} = \min_{0 \le t \le 30} C_t, \qquad G = \max\{0, R - C_{\min}\}. \tag{3}$$

其中 R 为用户现金底线，G 为预测底线缺口。路径包含今日和未来 30 天，共 31 个节点；最低值并列时取首次出现日。free 定义为 $C_{\min} - R$，可以为负值，不应直接称为可花余额。

事件包括既有账单、已登记的额外义务、有效订阅，以及尚未到账的预计工资。收到工资事件后，当前余额增加，同时移除预测中的这笔工资，防止重复计薪。延期改变预计到账日，移出观察窗口的收入不再计入 30 天路径。尚未确认的转账计划不是实际义务，不能因为模型提出建议就写入现金事实。

代码按每日开销和当日事件净额计算，只保存日终节点，不模拟同日先扣款后收入造成的日内缺口。第 0 天事件不在未来日循环中执行。当前演示账本与财务体检采用固定基准日，不能把输出称为已接入真实流水的滚动月报。

实现依据：backend/service.py:BankService._cash;backend/insights.py:build_insights。

3.2 一组可以独立复算的合成算例

设今日余额为 10,000 元，现金底线为 4,000 元，每日支出 100 元，第 5 天支付账单 3,000 元，第 10 天预计工资 6,000 元，第 12 天订阅扣费 100 元。以下均为说明算法而构造的输入，不是用户真实账本。

表 3　同一账本在不同条件下的现金最低点

条件	最低现金（元）	首次最低日	与底线比较
原条件，不转出	6,100	第 9 天	高于底线 2,100 元
原条件，立即转出 2,000 元	4,100	第 9 天	高于底线 100 元
原条件，立即转出 2,500 元	3,600	第 9 天	低于底线 400 元
工资延期 15 天，不转出	4,500	第 24 天	高于底线 500 元
延期后，仍转出 2,000 元	2,500	第 24 天	低于底线 1,500 元

原条件下第 9 天余额为 $10000 - 9 \times 100 - 3000 = 6100$ 元；延期后第 24 天为 $10000 - 24 \times 100 - 3000 - 100 = 4500$ 元。相同转账额在两种条件下得到不同核验结果，体现状态

变化对行动的约束。通过现金检查只说明这一组输入下的可行性，不产生用户授权，也不保证未来输入准确。

3.3　财务体检的证据与规则

体检复用服务端快照和现金路径，展示现金压力、小额支出、订阅复核项及其依据。单笔不超过 100 元且不属于内部调拨或还款的可见出账用于小额支出汇总；达到 2,000 元的出账或包含指令型文本的备注提示本人复核。低使用和重复订阅标记来自演示资料，不由模型假装推断真实使用频率。

现金低于用户底线时标记 urgent；没有现金缺口但存在复核信号时为 attention；没有上述信号时为 steady。这些是可解释规则状态，不是信用评分、欺诈判断或经过校准的风险概率。

取消单项订阅的比较，从窗口内对应续费日开始加回费用，不增加今日余额。由于最低点可能移动，多项取消对“最低余额改善”的影响不能把单项结果简单相加。体检同时列明数据、规则、未知项和决策边界；金融白话解释是只读知识入口，长辈模式只调整显示与关键确认信息的可读性。

3.4　生活规划的有限离散搜索

生活场景由用户声明金额、首选日、最晚日、重要性，以及是否允许替代或跳过。系统对保留原安排、缓冲优先、兼顾生活三种方案，比较基准、收入额外延期、突发支出、二者叠加四类压力条件。各情景没有估计概率；工资已到账时，延期情景可能与基准重合。

兼顾方案使用宽度为 128 的束搜索。候选日期来自首选日、最晚日以及允许窗口内的预计工资后日期，不逐日穷举；金额只保留用户原值、主动允许的替代金额，或在允许且非必要时跳过。必要场景不能自动取消。排序依次比较四情景下最坏支付缺口、最坏现金底线缺口、生活调整成本、节点缺口累计和日期指标；最终保留原安排与缓冲方案作为候选。

调整成本采用必要 100、重要 30、可调整 5 的演示权重，服务于可解释排序，不是估计效用或货币福利。有限束宽不保证全局最优。不动用资产只展示，不计入当前支付能力；缓冲敏感性固定同一方案与目标额，只改变初始现金假设。

采用生活安排会在事务中重算、复核双版本并登记未来义务，当前余额不扣款；采用不意味着所有压力情景均无风险。目标储蓄需另行生成转账草案，确认时走银行网关。生活分析、登记义务与实际付款具有不同状态，界面与回执必须分别表达。

实现依据：backend/life_planner.py:analyze,_choices,_rank,_policy;backend/life_service.py:commit_plan,propose_goal。

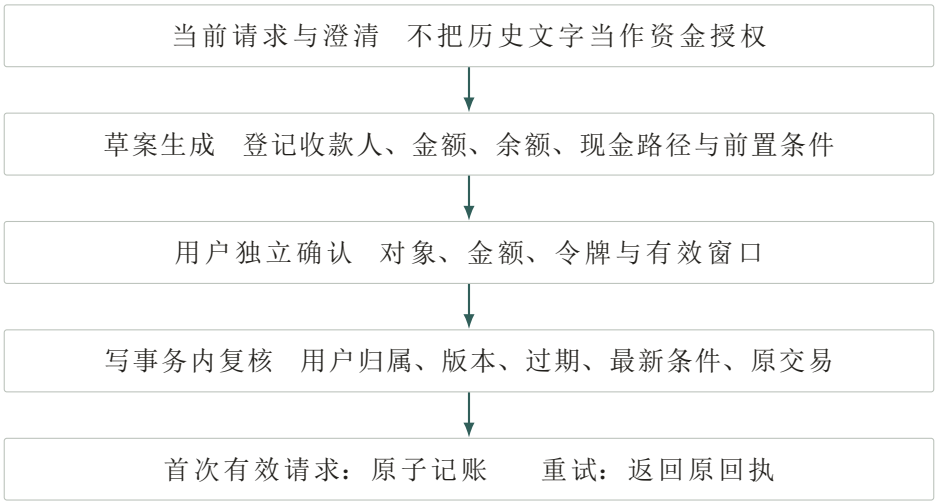
4. 对话办理与状态变更控制

4.1 从自然语言到待确认对象

对话层优先处理明确安全门与当前业务上下文，再选择本地规则、结构化理解、财务方案或普通只读回答。歧义收款人、缺失金额及不明确对象进入澄清，不能由模型凭空补齐。金额更正会创建新转账草案并撤销旧草案，已结算记录不能被聊天改写成未执行状态。

聊天中的“确认”展示确认入口，不直接执行转账。实际确认使用业务对象、精确令牌和明确布尔确认。对话并非完全只读：创建草案、写会话、撤销待办等可以改变服务端状态，但它们与资金记账不同。

图 2　普通转账从草案到回执的核验链



不通过的对象保持等待、阻断、失效或撤销状态；不能沿图示直通执行。

4.2 普通转账的草案与确认契约

普通转账草案核验登记收款人、合法金额、单笔不超过 50,000 元、当前已到账余额、转出后现金底线、未来现金路径和工资前置条件。检查通过时为 pending_confirmation；工资条件未满足时可以显示 waiting_condition，但该状态不表示其他检查已经通过。其余不可行条件为 blocked。

草案绑定用户、账户修订号、随机确认令牌和 600 秒有效期。确认要求 confirmation 严格为布尔值 true、读取同意、精确令牌以及当前账户版本；与生活目标关联的草案还检查生活版本与无待比较场景等条件。最终普通现金检查与记账位于同一写事务中。

部分状态是读取时投影，不是均以同名字段写回数据库。已结算交易优先投影为已执行；不得仅从展示字符串推断底层状态迁移。已记账交易不能通过撤销草案恢复到未执行。

表 4　普通转账状态的存储与展示口径

状态	含义及后续处理
pending_confirmation	草案生成时可行；确认时仍须复核
waiting_condition	工资等条件未满足；满足后重新准备或复核，不自动付款
blocked	当前金额、余额、现金路径或条件不满足
expired / stale	窗口过期，或账户、生活计划发生变化；重建有效草案
revoked	用户已撤销尚未结算的草案
settled / executed	数据存储记为 settled；已有交易时展示为 executed，查询原回执

事务以方案 ID 作为规范交易幂等标识；相同用户和方案已有交易时，在核验原确认信息后返回原回执。更换客户端请求键不会因此产生第二笔扣款。首次记账更新余额、两条方向相反的分录、交易、授权、审计与方案状态，并递增账户修订号。本地事务与唯一约束保证的是沙箱账本内的一致性，不能推广为外部支付系统的“恰好一次”承诺。

实现依据：backend/service.py:_propose_transfer,_present_proposal,confirm,_post,revoke。

4.3　多步骤任务与部分完成

复合请求最多处理八个分句，步骤分别标记只读完成、可确认、阻断、需澄清或拒绝。首次整单确认要求任务令牌、账户修订号、600 秒有效期和明确批准的步骤集合，只能批准当前可执行的步骤；挂失另需卡号后四位，但这不等于生产强身份认证。

执行按顺序推进：未批准的步骤记为跳过，成功步骤保留回执，业务失败步骤记为失败，之后获批准的步骤暂停。正常返回的任务终态 executed 表示整单执行尝试已经结束，可能包含全部跳过或部分失败，不能译为“全部成功”。重复确认返回原结果，跳过和暂停项不能在同一已结束任务中直接补做，应核对原结果后重新规划。

业务失败可以保留此前成功结果；未捕获异常则由外层事务回滚。转账与申购按前步骤更新后的账本核对资金。普通转账的 50,000 元限额不能未经核查推广为所有任务、所有入口或每日统一限额；“剩下的”金额分配还存在独立的额度计算规则。

当前不同变更入口的确认契约并不统一。单项订阅取消依靠显式确认、订阅状态与既有回执处理重试，没有普通转账草案的全部令牌、TTL 和调用方版本字段。卡片及理财任务的执行分支，也未逐一重复规划阶段的所有条件检查。后续应统一“对象、版本、时限、最新条件、幂等”的动作契约；本文不把局部保证写成全局保证。

实现依据：backend/agent_ops.py:plan,confirm,_execute;backend/service.py:_cancel_subscription。

5. 模型中心与受限智能编排

5.1 模型配置与本地回退

模型中心区分本地规则、平台模型和用户自带模型。平台密钥来自部署配置或可信本机管理员的运行时配置；个人 API Key 按认证用户隔离，仅存服务进程内存，重启后清除。选择状态属于用户自身，不应改变其他用户的模型选择。服务未配置、配置失效或输出不可用时，系统采用本地规则或明确失败说明。

表 5　代码中的供应商适配与使用条件

服务	适配路径	应核验的运行条件
DeepSeek	对话接口与检索适配	模型标识、凭据、当前检索入口与可用权限
OpenAI	Responses 与原生网页检索适配	选用模型及其工具支持、引用返回情况
Kimi	兼容对话与 Search Pro 适配	凭据、配额、模型与检索返回格式
千问	兼容对话及供应商专用能力适配	具体模型、思考开关、检索和输出方式
自定义	OpenAI 兼容入口	配置地址与服务端真实支持范围
本地规则	确定性解析与业务规则	无外部模型依赖，仍需用户确认写操作

该表描述项目代码适配，不是供应商全量能力清单，也不代表本次逐一完成真实联网验收。

5.2 发往模型的数据契约

普通意图理解主要使用当前用户消息；只读多轮问答可使用最近几轮文字帮助理解指代；生活或财务方案在同意读取画像后，使用服务端构造的财务汇总。汇总可包含余额、现金底线、现金路径、分类和必要账单合计，不主动附加原始流水备注、商户明细、收款账号、用户标识或会话令牌。

这项限制针对服务端构造的数据字段。用户自己输入或历史消息中可能已经含有姓名、账号、地址或其他敏感内容，不能据此承诺“任何敏感信息都不会发送”。API Key 不进入提示正文和响应回显，但用于所选供应商请求的鉴权。用户自带地址的信任与数据接收方应在选择模型时说明，不能把兼容接口等同于可信服务。

5.3 结构化方案与服务端上限

模型方案只是候选。服务端检查字段集合、重复 JSON 键、类型、有限数值、文字长度、金额合计、服务入口白名单与来源编号，并拒绝把尚未执行的动作写成已完成事实的输出。来源材料作为不可信证据使用，网页不能赋予付款权限；结果缺少可用来源时不包装成已经核实的联网结论。

财务方案的预算由服务端先计算上限，模型只能在上限内提出安排。当前确定性建议路径的上限为

$$U = \max\{0, \min(P,\ B - R,\ C_{\min} - R)\}, \tag{4}$$

其中收入稳定且无演示冲击时 $P = 2000$ 元，否则为 1000 元。这是当前非必要支出建议的演示策略上限，不是适用于所有转账的监管限额。生活规划的目标上限则取请求目标额、四压力情景的最低现金减底线、当前余额减底线三者的非负最小值。校验应使用对应接口返回的上限，不能以一个通用公式替代所有业务规则。

涉及金额的模型文本不能替代确定性计算，关键词或语义规则也不能证明所有幻觉都能被识别。当前实现依靠受限字段、动作白名单和最终执行网关控制实际副作用；自然语言错误仍须以准确的界面状态和回执予以纠正。

5.4　3.2.9 的千问稳定性修复

3.2.9 将千问普通自由对话调整为单次非流式请求，固定关闭该路径的 enable_thinking，减少隐藏思考消耗输出额度却没有可见回答的情况。连接测试采用一次最小只读对话，不再先理解再自然语言生成；上游失败后转本地只读规则，不在同轮悄悄追加兼容重试。

浏览器对只读对话、模型连接测试与交易类请求分别提示超时。只读超时不提示用户查询不存在的“原交易”；真实变更结果不明时则依据原凭证查询。修复只适用于已经调整的路径，不能推定所有模型、所有接口都固定非流式或关闭思考。

实现依据：backend/model.py;backend/model_center.py;assets/backend-client.js。

6.　购物链路与外部服务隔离

6.1　模拟购物与真实跑腿分开记账

Mock 链路覆盖合成商品搜索、预算核对、逐项确认、模拟扣款与模拟履约，状态如 mock_paid 只代表沙箱记录。官方连接器则通过用户授权与美团组件，读取真实地址、询价、准备帮买订单，确认后调用供应商，再由用户进入美团收银台完成真实支付。通用商品搜索仍使用 Mock 数据，不能据跑腿帮买宣称真实餐厅菜单外卖已打通。

表 6　两种购物链路的事实边界

比较项	Mock 购物	美团官方跑腿连接器
信息来源	合成商品与商户	授权地址、询价及供应商响应
确认后动作	沙箱订单与合成扣款	真实帮买订单提交及支付跳转
支付事实	仅模拟支付	由用户在美团侧完成，须查询真实状态
银行账本	写入合成交易与回执	不扣合成银行余额
失败处理	本地事务与原订单查询	保留未知状态、按原凭证核对，不盲目重提

6.2　用户授权与提交控制

官方链路须具备 Node 程序、Skill、授权助手和状态目录。每个用户先建立供应商授权，预览绑定用户、地址与询价条件。确认时检查对象归属、令牌、账户版本、过期和预算；较高配送费需要额外确认。订单创建只说明供应商接受了请求，不代表已经支付、接单或履约。

提交超时或结果不明时保留 unknown，限制同一询价直接重提。调用方应查询原订单状态并解释不确定性，不能因为没有及时收到响应便假定未下单。跨系统幂等能力取决于供应商契约，本地请求去重不能替代对方的执行保证。

真实配送必须向供应商提供收件姓名、电话、地址或坐标，以及物品要求、预算和备注。这是功能所必需的数据传输，与模型汇总字段裁剪是两种不同的数据边界。浏览器展示脱敏地址，不意味着供应商提交报文也只含脱敏信息。

6.3　组件调用与凭据空间

连接器通过参数数组启动 Node 子进程，不经 shell 拼接命令。授权缓存目录使用用户 ID 的 SHA-256 派生路径，子进程 HOME、临时目录与状态缓存分开配置；Linux 路径权限设置限制本机普通访问。该设计隔离凭据命名空间，不能等同于独立容器或操作系统级沙箱。

访问 Token 可能由官方授权助手缓存到文件，并在调用时进入子进程环境；部分询价凭证和供应商订单对象会保存到数据库。因此应区分模型密钥、供应商授权 Token、业务订单凭证和公开状态，不使用“所有第三方凭据都不落盘”这样的概括。

地址接口可能出现进程退出码为零但业务失败的情况，系统还需检查供应商业务响应。临时手动地址提供有限兜底，带 HMAC 签名的编码凭证用于完整性验证；签名不等于加密，不能把其中可解码内容当成保密存储。移动端提供打开授权页、手动刷新、重试与重新授权入口。

实现依据：backend/shopping.py;backend/meituan_paotui.py;scripts/package_meituan_connector.py。

6.4　邮件服务的真实副作用

配置 SMTP 时，邮箱验证与密码重置会向真实邮箱发送链接；未配置时，邮件落在权限受限的本机 outbox，属于开发行为，不表示用户已收到邮件。发送过程会向邮件服务提供收件地址。传输是否启用 STARTTLS 取决于配置，不能把可关闭的选项描述为任何环境下都已强制加密。

实现依据：backend/mailer.py。

7.　数据模型与身份安全

7.1　持久化对象与版本

SQLite 保存用户、画像、合成账户、交易、分录、幂等信息、方案、事件、对话、生活计划和购物状态。资源查询附带当前会话解析得到的用户 ID，不能由客户端请求字段任意替换归属。写事务采用 `BEGIN IMMEDIATE`，并用唯一约束保证用户范围内的请求去重。

表 7　主要持久化对象及用途

对象组	代表表	主要约束或版本
用户与画像	users, profiles, profile_updates	账户 revision、画像版本、授权读取状态
账本与回执	accounts, transactions, entries	整数分、交易唯一键、相反方向分录
请求与方案	idempotency, proposals, authorizations	请求指纹、令牌、有效期与用户归属
身份与挑战	auth_accounts, sessions, auth_challenges	口令及令牌摘要、消费状态与过期
多因素认证	mfa_settings, mfa_recovery_codes	TOTP 计数、防重放、恢复码单次消费
对话与任务	conversations, conversation_requests, missions	对话版本、资源引用、步骤执行结果
生活与购物	life_*, shopping_*	生活版本、账本版本、订单与供应商绑定

账户修订号用于发现财务事实变化；生活版本用于发现方案输入变化；对话版本用于并发消息与上下文一致性。三者并不互相替代。对话请求指纹绑定用户、消息与原会话标识，同键异内容应拒绝；重放可以重新读取业务资源状态，而不是把历史文本里的完成描述当作最新事实。

7.2　注册账户与共享演示账户

注册账户生成独立用户 ID 和合成账本。密码使用独立盐值的 scrypt 慢哈希；会话令牌使用高熵随机值，数据库保存摘要，有效期为 24 小时。连续五次错误口令触发 15 分钟

限制；重置密码撤销已有会话。验证与重置链接使用短期、单次消费挑战，邮箱未验证并不阻止当前注册流程立即签发会话，不能把邮箱验证称为所有访问的强制前置条件。

TOTP 支持计数防重放与一次性恢复码，登录挑战窗口为五分钟。TOTP 相关秘密依赖服务端主密钥派生与绑定状态；主密钥需要持久化并妥善备份，轮换可能使已有绑定失效。这些控制不包含实名、活体或真实银行卡验证。

A/B/C 为共享演示身份，同一演示 persona 的访客复用同一用户空间。注册账户之间的数据隔离，不意味着共享演示账号的每位访客都独立隔离；同一演示用户的模型与供应商绑定也可能共享。真实授权应使用本人注册账户，并清楚告知数据接收方。

7.3　接入校验与权限边界

网关检查 Host、Origin、Sec-Fetch-Site、方法、路径、JSON 类型与请求大小，并设置缓存、内容类型、引用来源和 CSP 等响应策略。公开健康检查及部分认证入口不要求既有会话，业务资源则由会话绑定用户。生产 HTTPS 由 Caddy 终止，Python 接入层提供 HTTP 与应用校验。

表 8　主要威胁与控制落点

威胁	现有控制	保证范围
跨用户读取或修改	会话绑定用户、对象查询带用户条件	注册用户资源；共享 persona 不是访客级隔离
模型越权与注入	不可信输入隔离、动作及字段检查、执行网关	不代表能识别所有自然语言攻击
过期方案与并发变化	修订号、生活版本、TTL、事务内复核	契约依业务入口而异
重复扣款与网络重试	用户范围唯一键、原方案交易查询、原回执	本地合成账本，不外推到供应商清算
凭据泄漏	摘要存储、密钥不回显、状态目录隔离	用户输入、供应商缓存与日志仍需单独治理

7.4　可信本机配置与残余风险

--model-admin 是可信本机演示开关，不是经过独立管理员角色认证的权限系统。开启后不应让不可信用户访问；公网运行应通过部署环境管理平台密钥。个人模型服务地址的配置校验，也不能证明目标服务值得信任。

反向代理会改写部分请求头，后端看到的 Host 和 Origin 不一定是浏览器原始值，因此应结合实际代理策略评估跨站防护，不能仅列后端头部检查就宣称链路全程保留了原始来源证明。Caddy 可记录请求日志，后端不打印路径不等于整个链路没有日志。真实地址、认证回调、查询参数和凭据缓存都需要适当的访问、保留及清理策略。

8. 部署拓扑与运行维护

8.1 运行环境与服务入口

后端声明最低 Python 3.10，主体使用标准库；这不表示每个受支持小版本均已完成同等测试。项目 Dockerfile 使用 Python 3.13，并从 Node.js 22 镜像复制 Node 可执行文件。Node 用于官方跑腿及授权组件，也用于前端测试，不是 Python 银行业务服务的替代运行时。

本次文档核验使用 macOS、Python 3.12.14 和 Node.js 24.22.1。它与 Docker 构建声明不同，应分别记录；未提供镜像摘要或容器内版本实测时，不以镜像主版本宣称已完成目标容器验收。

```
./scripts/run.sh
# 或在项目根目录运行
python3 -m backend.server --host 127.0.0.1 --port 8765 \
  --db .local/tropos.sqlite3
```

首页为 index.html，完整工作台为 demo.html。局域网演示需要显式配置访问方式；设备互访还取决于防火墙与网络隔离。开放演示模式必须视为可修改共享合成状态的环境，不能作为生产访问控制。

8.2 Linux Docker 与 HTTPS

当前 Compose 中应用与 Caddy 都使用 host 网络。应用监听宿主机回环 127.0.0.1:8765，Caddy 在同一宿主网络上接收站点流量并反向代理该地址；配置中没有额外的应用 ports 发布映射。该拓扑面向 Linux 主机，不能直接推定其他操作系统具有完全相同的 host 网络行为。

应用使用 UID 10001 非 root 用户、只读根文件系统、no-new-privileges 和受限临时目录。数据库、官方组件及授权状态通过明确目录挂载；组件只读与授权缓存可写需要分别配置权限。配置存在不代表目标服务器的目录属主、域名证书和外网端口已经验收。

表 9　关键部署配置及缺失时的行为

配置组	配置入口	缺失或错误时的影响
站点与邮件	TROPOS_SITE_ADDRESS、TROPOS_PUBLIC_URL、TROPOS_SMTP_*	域名、回调或邮件功能不可据启动成功推定就绪
认证主密钥	TROPOS_AUTH_MASTER_KEY 及本地持久化位置	自动生成只适于明确管理的环境，丢失或轮换影响 MFA
模型服务	TROPOS_DEEPSEEK_* 等各服务配置	服务不可选或规则降级；真实调用仍依赖供应商权限
美团组件	TROPOS_MEITUAN_*	官方链路不可用，Mock 可独立运行

8.3　升级与故障恢复

3.2.x 提供基础 Compose 与版本覆盖文件。更新前备份数据库、配置、认证主密钥与供应商状态，核对挂载目录、UID 和目标镜像；更新后检查健康版本、登录、读取、草案、确认与原回执查询。数据库结构兼容与状态迁移应按实际升级路径验证，不能承诺任何旧版本都能无迁移替换。

```
curl -fsS http://127.0.0.1:8765/api/health
```

健康接口返回 version 为 3.2.9 只说明服务版本与基础可访问性，不代表 SMTP、真实模型、美团授权和支付均可用。故障时先区分只读请求、已创建草案、已提交订单和结果未知的交易，再按原凭证查询；不以重启或再次提交代替状态核对。

9.　验证方法与本次核验结果

9.1　可复现基线与计数口径

本次以 2026 年 11 月 2 日本地工作区复跑自动化测试。核心后端提交为 2a33063，界面包含尚未提交的水墨风更新，因此结果归属于工作区快照，而非声称某个完全干净的发布提交已经在全部环境验收。源码 SHA-256、运行命令、解释器版本和日志随 LaTeX 源码包的 evidence/ 提供。

表 10　本次本机复跑结果

检查层	实际计数	解释与范围
Python unittest	共 470；成功 469；跳过 1；失败与错误 0	包括身份、账本、模型替身、HTTP、生活与连接器等测试
Node 测试运行器	101 项；通过 101；失败 0；跳过 0	tests/*.cjs；并不等于独立的真实浏览器用户测试
规则模式红队	攻击 62/62；正常对照 14/14	对话攻击 51 项、API 绕过 11 项；当前工作区复跑

Python 跳过项为 test_windows_does_not_apply_unix_chmod_to_credential_directories，原因是仅验证 Windows 的凭据目录行为，本次 macOS 不适用。跳过不是通过；本次结果也不替代 Windows 实机验证。470 是 unittest 发现并运行的测试总数，已经包含跳过项，不能写成“470 成功再加 1 跳过”。

本次数字按所列命令与日志统计。历史发布材料中的数字需要结合各自日期、环境和计数单位阅读，不能直接替代当前结果。不同层的用例可能重叠，红队场景与 Python 回归也有交叉，不合计为独立覆盖总量。

```
python3 -m unittest discover -s tests -p 'test_*.py' -v
node --test tests/*.cjs
```

9.2　红队样例与结论边界

锁定样例集包含开发者构造的直接及间接注入、身份冒充、错误完成声明、收款人混淆、金额异常、多步夹带和 API 绕过等场景。攻击通过指不产生攻击者要求的可授权写动作或真实执行，账本保持预期状态且回复不虚称完成；正常对照通过指预期写动作以待授权形式出现，不能把“对照可办理”误写成已经付款。

本次通过 eval.redteam.benchmark(live_model=False) 在规则模式复跑，将结果单独保存，不覆盖仓库历史报告。历史 reports/redteam.json 属于 2026 年 10 月 28 日 7ac1c9c 基线；本次的工作区结果与历史记录分别保留。未调用真实付费模型，也未创建真实美团订单。

62/62 是已知开发样例的回归结果，不是未知攻击拦截率、统计泛化结论或安全认证。模型适配测试大量使用回环 Mock，能检查协议参数和降级行为，不能证明供应商当前账号权限、网络与真实端到端稳定性。

9.3　与技术主张对应的证据

表 11　关键主张与核验入口

技术主张	代码与测试入口	尚不能据此推出
确认前不产生普通转账扣款	service.py:confirm；转账与 API 测试	所有外部交易均可撤销
同一方案不重复记账	交易唯一约束、幂等回执及并发测试	供应商清算恰好一次
现金路径可复算	_cash、生活规划参考路径测试及本文算例	日内风险全覆盖或实际到账保证
注册用户数据分区	test_auth.py 与对象归属检查	共享演示账号访客彼此隔离
模型失败可降级	test_model.py 中回环替身与错误响应测试	所有供应商真实调用均已验收

真实手机网络、无障碍用户盲测、供应商真实授权支付、目标 Linux 部署、压力与渗透测试需要分别记录环境、输入、结果和失败。功能测试成功不能替代可用性或生产安全验收。

10. 版本演进与后续工作

10.1 3.2 系列的工程收敛

3.2 将已有转账、账单与订阅能力连接到可解释财务体检，并补充术语解释、长辈友好显示、模型中心与注册账户。后续迭代集中在三个方面：认证交互与输入一致性，官方跑腿组件的授权、部署与错误处理，以及模型自由对话、来源和超时语义。3.2.9 的主要落点是千问普通对话与连接测试的稳定请求策略。

版本号并不增加已经验证的能力范围。水墨视觉更新改善项目表达；财务算法、交易状态与外部服务仍按本文定义运行。发布前应把前端、后端、配置、数据库兼容与验证证据绑定到同一可追溯快照。

10.2 优先完成的工程改进

1. **统一动作确认契约。**将普通转账、多步骤任务、订阅、卡片与理财变更逐一映射到相同的核验清单；尤其补齐执行时的锁定期、卡状态等业务重验，明确各入口的限额、版本和时限，不依赖规划时曾经检查过的条件。
2. **细化任务终态与恢复。**将整单执行尝试结束与全部成功区分，面向用户展示部分完成、失败及暂停项；重新办理时引用原回执，避免补做任务导致重复。
3. **收紧对外数据控制。**对当前消息、历史、目标名称和检索词提供清楚的发送提示与可测试的字段治理；对真实美团地址、供应商响应和缓存建立保留与访问策略。
4. **分开演示与真实授权空间。**共享 persona 用于合成演示，真实外部账号使用独立注册身份。公网配置平台密钥应采用明确管理员身份与最小权限，而不是仅依靠本机开关。
5. **完善目标环境验证。**固化 Linux 镜像与官方组件版本，补 Windows、真实手机及外部服务验收，建立备份恢复和关键状态观测。SQLite 单机适用于当前演示；多实例演进需重新设计数据库锁、共享任务与幂等边界。

10.3 面向更完整金融生活的方向

项目可以继续探索家庭协同、跨账户资金视图、小微经营中的应收应付与回款压力，以及更长时期的目标衔接。前提是获得相应数据与授权，明确金融业务资质、供应商契约和可验证的决策边界。不能把当前 30 天有限模型外推为已经实现的完整生命周期优化。

TROPOS 的长期方向仍是同一件事：理解人的处境，让安排跟随变化，同时把决定权与可追溯的结果留给用户。技术演进应以这一要求衡量，而不是以增加模型数量或场景数量作为完成标准。

A. 接口与工程核对索引

A.1 主要接口契约

以下列出代表入口，完整字段和错误行为以 backend/server.py 及对应服务测试为准。公开入口与登录业务入口分开；需要变更状态的请求不因路径存在就绕过用户确认。

表 12　代表性 HTTP 接口

方法	路径	用途
GET	/api/health	公开健康与版本
POST	/api/auth/register /api/auth/login	注册和登录
POST	/api/auth/email/verify /api/auth/password/reset	单次挑战验证与密码重置
GET	/api/state /api/insights	当前快照与财务体检
GET	/api/financial-glossary	只读金融术语
POST	/api/agent	对话理解与业务分派
GET	/api/conversations/{id}	恢复对话与资源状态
POST	/api/transfers/propose	生成普通转账草案
POST	/api/proposals/{id}/confirm	确认有效草案
POST	/api/missions /api/missions/{id}/confirm	多步骤规划与逐项批准
POST	/api/life/analyze /api/life/commit /api/life/goal	比较、登记义务、另建目标草案
GET	/api/model-center	模型配置状态与能力投影
PUT	/api/model-center/selection	当前用户选择模型
POST	/api/shopping/paotui/preview	官方帮买预览
POST	/api/shopping/paotui/previews/{id}/confirm	逐项确认并提交官方订单

A.2　工程模块与核查函数

表 13　核心实现索引

文件	代表函数或对象	重点核对内容
backend/service.py	_cash, _checks, confirm, _post	现金路径、复核、记账与幂等
backend/conversation.py	turn, _draft_transfer, _refresh	对话版本、草案更正和恢复
backend/agent_ops.py	plan, confirm, _execute	多步骤部分执行与回执
backend/life_planner.py	analyze, _choices, _rank	四情景、离散选择、束宽与排序
backend/life_service.py	commit_plan, propose_goal	登记义务与目标草案分离
backend/insights.py	build_insights	可见数据统计与解释规则
backend/model.py	模型适配、建议验证与本地策略	预算、数据发送与失败语义
backend/model_center.py	用户选择、配置与能力状态	平台配置及个人密钥边界
backend/meituan_paotui.py	组件调用与用户目录管理	参数数组、缓存与供应商错误
backend/shopping.py	Mock 与官方订单业务	订单未知状态和账本分离
backend/server.py	HTTP 路由与接入校验	会话归属、方法、头部与参数
deploy/docker-compose.yml	应用与 Caddy host 网络	回环上游与目录挂载

A.3　交付与复现

主文件为 main.tex，分节正文在 sections/，项目 logo 与长卷原件在 assets/。使用 kit 的中文 paper 日常版，以 XeLaTeX 编译；环境与依赖说明见源码包 README。

```
latexmk -xelatex -interaction=nonstopmode \
  -halt-on-error main.tex
```

evidence/ 保存测试日志、规则红队报告、代码指纹与核验说明，用于追溯本次结果。源码包不包含用户数据库、密钥或供应商认证材料。